

Assignment: VFD Cybersecurity Deliverables

Assigned to: Manal

Project: VFD Cyber Resilience Analysis — BSI TR-03183-1 & EU CRA

Deliverables: 3 documents (VFD_RiskID, VFD_StdMapping, VFD_SecurityReqs)

Background — Read This First

What is a VFD?

A Variable Frequency Drive (VFD) is an electronic device that controls the speed of an electric motor by varying the frequency and voltage of the power supplied to it. It is widely used in industrial systems to control pumps, fans, compressors, and conveyor belts.

A VFD has the following key components:

- **Power input stage:** receives AC power from the grid
- **DC bus:** converts AC to DC internally
- **Inverter stage (IGBTs):** converts DC back to variable AC for the motor
- **Control board:** the brain — runs firmware, processes commands, manages safety
- **Communication interfaces:** Modbus RTU/TCP, Ethernet, USB, HMI — these are how the VFD receives commands and sends data
- **Gate drivers:** translate control signals into power switching commands

From a cybersecurity perspective, the attack surface of a VFD is its **external communication interfaces** — Modbus, Ethernet, USB, and HMI. An attacker who can send commands through these interfaces can manipulate motor speed, disable safety mechanisms, or tamper with firmware.

What is BSI TR-03183-1?

The BSI TR-03183-1 is a technical guideline published by the German Federal Office for Information Security (BSI). It defines cyber resilience requirements for products, aligned with the EU Cyber Resilience Act (CRA). It contains three categories of requirements:

- **REQ_ER:** Product properties (what the product must do/be)
 - **REQ_VH:** Vulnerability handling (how vulnerabilities are managed)
 - **REQ_TD/UD:** Documentation requirements
-

What is the EU CRA?

The EU Cyber Resilience Act is a European regulation that mandates cybersecurity requirements for products with digital elements sold in the EU. It defines essential requirements in Annex I and documentation requirements in Annex II.

What is MITRE ATT&CK for ICS?

MITRE ATT&CK for ICS is a publicly available framework that catalogs tactics, techniques, and procedures used by attackers targeting industrial control systems. Each tactic has an ID (e.g., T0855 = Unauthorized Command Message). We use it to ground our threat analysis in real-world attacker behavior.

Impact Prioritization

In industrial systems, impact is prioritized differently from IT systems:

1. **Safety** — can someone get hurt or killed?
2. **Availability** — does the system stop working?
3. **Integrity** — is the data or behavior tampered with?
4. **Confidentiality** — is sensitive information exposed?

This order is important: in a VFD, stopping a motor unexpectedly can cause physical injury — so Safety always comes first.

Deliverable 1: VFD_RiskID — Risk Identification Document

Purpose

Identify and document all credible cybersecurity threats to the VFD system.

Required Contents

1. System Description

- Brief description of the VFD and its role in the industrial environment
- List of all external interfaces (Modbus, Ethernet, USB, HMI, I/O, Encoder)
- Definition of the TOE (Target of Evaluation) boundary: what is inside scope vs outside

2. Threat Agent Profiles For each type of attacker, describe:

- Who they are (insider, remote hacker, nation-state, etc.)
- Their motivation
- Their capability level
- Their likely entry point into the VFD

3. Threat Scenarios (minimum 8, target 15) For each threat, provide:

- Threat ID (e.g., T-01)
- Threat name
- Description of the attack
- Entry point / attack vector
- Preconditions (what must be true for the attack to work)
- MITRE ATT&CK for ICS tactic ID
- Impact scores: Safety / Availability / Integrity / Confidentiality (None / Low / Medium / High / Critical)
- Likelihood (Low / Medium / High)
- Feasibility (Low / Medium / High)
- Risk Priority Number (RPN) = Impact × Likelihood × Feasibility (score each 1–3, multiply)

Threat categories to cover (at minimum):

- Unauthorized Modbus command injection
- Firmware tampering
- Default credential exploitation
- Physical port access (USB)
- Denial of Service on control interface
- Man-in-the-middle on communication bus
- Supply chain compromise
- Insider threat

4. Risk Matrix A table or visual showing all threats plotted by Likelihood vs Impact.

5. References

- BSI TR-03183-1 requirement IDs referenced
 - MITRE ATT&CK for ICS tactic IDs used
-

Deliverable 2: VFD_StdMapping — Standards Mapping Document

Purpose

Show how the BSI TR-03183-1 requirements map to other standards, and assess coverage.

Required Contents

1. Compliance Hierarchy Overview A brief description (not a diagram) of the hierarchy: EU CRA → BSI TR-03183-1 → IEC 62443 / ETSI EN 303 645 → VFD

2. Mapping Table For each BSI requirement (REQ_ER, REQ_VH, REQ_TD), provide:

- BSI Requirement ID and name
- Requirement description (plain language)
- Corresponding IEC 62443 clause (if applicable)
- Corresponding EU CRA Annex I / Annex II essential requirement
- Corresponding ETSI EN 303 645 provision (if applicable)
- Coverage status: Fully Covered / Partially Covered / Not Applicable

3. Coverage Analysis

- How many requirements are fully covered?
- Which are only partially covered and why?
- Are there any gaps?

4. Recommendations For each gap or partial coverage, what additional control or measure would close it?

Deliverable 3: VFD_SecurityReqs — Security Requirements Specification

Purpose

Define the specific security requirements the VFD must meet, traceable to threats and standards.

Required Contents

1. Requirements List (minimum 30, target 40+) Organize by category:

- **AC** — Access Control
- **CR** — Cryptography
- **IN** — Input Validation
- **UP** — Update & Patch Management
- **LOG** — Logging & Monitoring
- **CFG** — Secure Configuration
- **AV** — Availability & Resilience
- **VH** — Vulnerability Handling

- **DOC** — Documentation

For each requirement, provide:

- Requirement ID (e.g., AC-01)
- Requirement statement ("The VFD shall...")
- Rationale (why this requirement exists)
- Linked threat ID(s) from VFD_RiskID
- Linked BSI requirement ID
- Linked IEC 62443 clause
- Verification method (Test / Inspection / Analysis / Review)
- Priority (Must Have / Should Have / Nice to Have)

2. Traceability Matrix A table linking: Threat ID → Requirement ID(s) → BSI Source → Standard

3. Implementation Guidance For each category, 2–3 sentences on how to implement the requirements in a VFD context (e.g., for AC: "Access control on a VFD can be implemented through role-based authentication on the HMI and Modbus command whitelisting...")

Submission Format

- File format: .docx or .md
- Language: English
- Naming: VFD_RiskID_v1.0, VFD_StdMapping_v1.0, VFD_SecurityReqs_v1.0
- Commit directly to a branch and open a PR for review